SC-900 Notes

By Om Joshi

Microsoft Security, Compliance & Identity Fundamentals

GitHub: https://github.com/iamomjoshi

LinkedIn: https://in.linkedin.com/in/om-joshi-327bb8314

Table of Contents

1 Security, Compliance & Identity Concepts

- Zero Trust Model · Pillars & Domains
- Defense-in-Depth · Seven Layers
- Shared Responsibility Model
- Encryption
- Symmetric, Asymmetric, Hashing
- Governance, Risk & Compliance (GRC)
- Identity as the Primary Security Perimeter

2 Microsoft Entra ID Capabilities

- Six Identity Types Explained
- Authentication vs Authorization
- Multi-Factor Authentication (MFA)
- Passwordless Authentication
- Conditional Access
- Identity Governance & PIM
- Active Directory vs Entra ID
- Federation & External Identities

3 Microsoft Security Solutions

- Network Security
- NSG, DDoS, Firewall, WAF, Bastion
- Azure Key Vault & Data Encryption
- Defender for Cloud & CSPM
- Microsoft Sentinel
- SIEM & SOAR
- Defender XDR
- Full Suite

4 Microsoft Compliance Solutions

- Microsoft Purview Platform
- Sensitivity Labels & Data Classification
- Data Loss Prevention (DLP)
- Retention, Records & eDiscovery
- Insider Risk & Communication Compliance
- Azure Policy, Blueprints & Resource Locks

1. Security, Compliance & Identity Concepts

Security, Compliance, and Identity (SCI) are three interconnected disciplines that form the foundation of modern IT risk management. Security focuses on protecting systems and data from threats. Compliance ensures organizations adhere to laws, regulations, and internal policies. Identity management controls who or what can access resources. Together, these three pillars protect organizations from the inside out — covering people, data, devices, and the infrastructure they run on.

Zero Trust Model

Zero Trust is a modern security philosophy built on one simple principle: never trust, always verify. Traditional network security assumed that everything inside the corporate network was safe. That model no longer works in a world of cloud services, remote work, and personal devices. Zero Trust treats every access request — whether it comes from inside or outside the network — as potentially hostile until proven otherwise. Every user, device, and application must continuously prove it deserves access.

The Three Zero Trust Pillars

Pillar	What It Means	Real-World Example
Verify Explicitly	Always authenticate and authorize using all available signals — identity, device health, location, time of day, and behavioral risk. Never assume that a previous login is good enough.	A bank requires a secret confirmation code for every fund transfer, even after you have already logged into the app.
Use Least Privilege	Grant only the minimum access rights needed, for the minimum time required. Use Just-in-Time (JIT) and	When a manager goes on vacation, their substitute receives short-term elevated access only for the tasks that

	Just-Enough-Access (JEA) models. If a task does not require admin rights, do not grant them.	require it — and only while needed.
Assume Breach	Design and operate as if the network has already been compromised. Encrypt data at rest and in transit everywhere. Segment access. Use analytics to detect threats. Minimize blast radius.	Sensitive data is encrypted at rest and in transit even between servers inside the same data center — so a compromised internal server cannot read neighboring data.

The Six Zero Trust Domains

Zero Trust extends across six protection domains, each requiring its own verification and security strategy:

- Identity: Verify every identity with strong authentication. Use MFA, Conditional Access, and PIM. Monitor for risky sign-ins and credential compromise.
- Devices: Ensure every device is compliant, patched, and healthy. Enforce device enrollment and compliance policies via Intune.
- Applications: Apply appropriate in-app permissions. Monitor user actions within applications. Use Conditional Access to control which apps can be accessed from which device or location.
- Data: Classify and label data based on sensitivity. Encrypt data at rest and in transit. Restrict access based on data classification, not just user identity.
- Infrastructure: Monitor telemetry from servers, containers, and services. Detect attacks and risky configurations. Apply just-in-time VM access to reduce exposure.
- Network: Encrypt all communications. Segment networks to limit lateral movement. Treat every network connection — even internal ones — as untrusted.

Key Concept: *Just-in-Time (JIT) access means privileged roles are NOT permanently assigned. A user must request elevation, provide a reason, and receive a time-limited grant. Just-Enough-Access (JEA) means they receive only the permissions needed for that specific task — nothing more.*

Defense-in-Depth

Defense-in-depth is a layered security strategy. Rather than relying on a single control, multiple independent layers of protection are applied. If an attacker breaks through one layer, they immediately face the next. This philosophy mirrors how medieval castles were built: moat, drawbridge, outer wall, inner wall, guards, and vault. Each layer slows the attacker and increases the likelihood of detection.

Layer	Name	How It Protects
1	Physical Security	Protects the physical hardware. Datacenter access controls, biometric entry, 24/7 guards, surveillance cameras.
2	Network Security	Controls traffic entering and leaving. Firewalls, NSGs, DDoS protection, VPN, and network segmentation.
3	Host Security	Secures individual servers and OS. OS hardening, patching, antimalware, Defender for Endpoint, host-based firewalls.
4	Application Security	Builds security into apps. Secure coding, OWASP protection, Web Application Firewall (WAF), vulnerability scanning.
5	Data Security	Protects data directly. Encryption at rest and in transit, access controls, sensitivity labels, and backup policies.

6	Identity & Access	Verifies who is accessing resources. MFA, Conditional Access, PIM, RBAC, SSO. The most critical modern layer.
7	Threat Detection	Monitors all layers continuously. Sentinel SIEM, Defender for Cloud alerts, behavioral analytics, AI-driven anomaly detection.

Shared Responsibility Model

When an organization moves to the cloud, security responsibilities are divided between Microsoft and the customer. The exact split depends on the service model. The further into the cloud you move (from IaaS to PaaS to SaaS), the more Microsoft takes on. However, certain responsibilities always remain with the customer.

Responsibility Area	On-Premises	IaaS	PaaS	SaaS
Physical Datacenters	Customer	Microsoft	Microsoft	Microsoft
Network Infrastructure	Customer	Microsoft	Microsoft	Microsoft
Host Infrastructure / OS	Customer	Customer	Microsoft	Microsoft
Application Runtime	Customer	Customer	Microsoft	Microsoft
Application Code	Customer	Customer	Customer	Microsoft
Data Classification & Handling	Customer	Customer	Customer	Customer
Identity & Access Management	Customer	Customer	Customer	Customer

Endpoint / Device Security	Customer	Customer	Customer	Customer

Always Customer: *No matter which cloud model you use, three responsibilities always stay with the customer: data classification and handling, identity and access management, and endpoint/device security. These never shift to Microsoft.*

Encryption & Hashing

Cryptography is the science of securing information. Microsoft uses industry-standard cryptographic techniques throughout Azure and Microsoft 365 to protect data at rest, in transit, and to verify integrity. There are three main concepts: symmetric encryption, asymmetric encryption, and hashing.

Symmetric Encryption

Symmetric encryption uses a single shared key for both encrypting and decrypting data. Both the sender and receiver must possess the same secret key. This makes it fast and efficient for large amounts of data, but requires a secure method of exchanging the key.

Algorithm	Key Size	Notes & Usage
AES (Advanced Encryption Standard)	128, 192, or 256-bit	Current industry standard. Used everywhere in Azure for data-at-rest encryption. Also used in WhatsApp end-to-end encryption.
DES (Data Encryption Standard)	56-bit	Legacy — too weak for modern use. A 56-bit key can be brute-forced with today's hardware.
IDEA	128-bit	International Data Encryption Algorithm. Used in PGP email encryption historically.

Blowfish	32–448-bit	Drop-in replacement for DES. Still found in some legacy systems.

Asymmetric Encryption

Asymmetric encryption uses two mathematically linked keys — a public key and a private key. Data encrypted with the public key can only be decrypted with the corresponding private key. The public key can be shared freely. The private key must be kept secret. This solves the key exchange problem, making it ideal for securing internet communications.

Algorithm	Key Size	Notes & Usage
RSA	2048–4096 bits	Most widely used. Secures HTTPS/TLS web traffic. Public key encrypts; private key decrypts.
ECC (Elliptic Curve Cryptography)	256–521 bits	Provides equivalent security to RSA with much smaller key sizes. Used in Bitcoin and modern TLS.
Diffie-Hellman	Varies	Key exchange protocol. Allows two parties to establish a shared secret over a public channel without transmitting the key.
ElGamal	Varies	Used in newer versions of PGP (Pretty Good Privacy) for email encryption.
DSA (Digital Signature Algorithm)	1024–3072 bits	US Government FIPS standard for digitally signing messages — not encryption.

Hashing — One-Way Functions

Hashing is fundamentally different from encryption. A hash function takes any input and produces a fixed-length output called a digest. This process is irreversible — you cannot work backwards from a hash to recover the original

input. Hashing is used to verify data integrity and to store passwords securely without ever storing the actual password.

Algorithm	Output Size	Notes & Usage
MD5	128 bits	Legacy — broken. Do not use for security. Still used for checksums where security is not critical.
SHA-1	160 bits	Deprecated for security use. Collision vulnerabilities found. Still seen in legacy systems.
SHA-256 / SHA-3	256 / 512 bits	Current standard. Used in TLS certificates, Azure integrity checks, and code signing.
bcrypt	Variable	Password-specific. Includes built-in salting and work factor. Deliberately slow to resist brute-force.
PBKDF2 / scrypt	Variable	Password-specific. PBKDF2 is NIST recommended. scrypt is memory-hard for GPU attack resistance.

Password Security Techniques

Three techniques strengthen password hashing in storage systems:

- Salting: A random unique value is added to each password before hashing. This means two users with the same password will have completely different hashes, making pre-computed rainbow table attacks useless.
- Peppering: A secret server-side value is mixed into the hash before storage. Unlike the salt, the pepper is not stored in the database — it is kept in application configuration.
- Work Factors: The hash function is configured to require significant computing power, making it deliberately slow. A legitimate login takes milliseconds; brute-forcing millions of passwords becomes computationally infeasible.

Governance, Risk & Compliance (GRC)

GRC is a structured framework that aligns an organization's IT activities with its business objectives while managing risks and satisfying regulatory requirements. A mature GRC program enables data-driven decision making, responsible operations, and systematic cybersecurity improvement.

Pillar	Detailed Definition	Frameworks & Examples
Governance	A set of policies, rules, and frameworks designed to ensure the organization achieves its goals ethically and legally. Defines accountability structures, decision rights, and performance measurement.	COBIT, NIST CSF, ISO 27001, CIS Controls
Risk Management	The process of identifying threats the business faces, assessing their likelihood and impact, and implementing controls to reduce them to an acceptable level. Risk is never fully eliminated — it is managed.	Risk registers, NIST RMF, threat modeling, risk appetite statements
Compliance	Following external rules — laws passed by governments, regulations from industry bodies, and contractual obligations. Requires not just adherence but the ability to demonstrate and prove it.	GDPR, HIPAA, PCI-DSS, SOX, CCPA, ISO 27001 certification

Key Compliance Regulations

Acronym	Full Name	Jurisdiction	What It Protects

GDPR	General Data Protection Regulation	European Union	Personal data and privacy rights of EU residents. Requires consent for data collection, right to erasure, mandatory breach notification within 72 hours.
HIPAA	Health Insurance Portability & Accountability Act	United States	Protected Health Information (PHI). Requires physical, administrative, and technical safeguards.
PCI-DSS	Payment Card Industry Data Security Standard	International	Credit and debit card data. Required for any organization that stores, processes, or transmits cardholder data.
CCPA	California Consumer Privacy Act	USA — California	California residents' rights over their personal data: right to know, delete, opt out of sale.
SOX	Sarbanes-Oxley Act	United States	Requires US-listed public companies to maintain accurate financial records and internal controls to prevent fraud.

Microsoft 365 Maturity Model

The M365 Maturity Model provides a roadmap for organizations to progressively improve their security and compliance practices across five levels:

Level	Name	Characteristics
100	Initial	Firefighting mode. No formal controls. Reactive — problems are addressed after they occur. No documentation.

200	Repeatable	Basic awareness exists. Some informal controls. People know there is a problem but solutions are inconsistent.
300	Defined	Formal, documented processes. Training programs exist. Controls are deployed consistently across the organization.
400	Managed	Processes are measured and monitored. Metrics drive continuous improvement. Management receives regular reports.
500	Optimizing	Security is strategic. Automation reduces manual effort. Predictive analytics anticipate threats before they occur.

Identity as the Primary Security Perimeter

For decades, corporate security was built around the network perimeter — a strong boundary separating trusted insiders from untrusted outsiders. If your device was on the corporate network, you were trusted. That model has been fundamentally broken by three forces: cloud computing, remote work, and BYOD (bring your own device). Identity has replaced the network as the primary security perimeter.

Old Security Assumption	Modern Reality
Person is trusted because they are on the corporate network	Identity must be VERIFIED with strong authentication — MFA, Entra ID, behavioral analytics
The corporate network is a trusted zone	Employees work from home, coffee shops, hotels — on any network
Only company-owned devices connect to company systems	BYOD — employees use personal phones, tablets, and laptops

Applications and services live inside the data center	Cloud apps live in Azure, AWS, Google Cloud, and third-party SaaS

Modern Identity Security Capabilities

- Single Sign-On (SSO): One login grants access to many applications via token sharing. Reduces password fatigue and improves security.
- Multi-Factor Authentication (MFA): Requiring more than one proof of identity dramatically reduces account compromise — blocks over 99% of credential-based attacks.
- Just-in-Time Access: Users only receive privileged access when they actively request and justify it — no permanent standing admin rights.
- Intelligent Monitoring: Machine learning analyzes sign-in patterns to flag unusual behavior — new location, new device, unusual time.
- Least Privilege / Default Deny: Access is denied by default. Users receive only the minimum permissions required for their specific role.

2. Microsoft Entra ID Capabilities

Microsoft Entra ID — formerly known as Azure Active Directory (Azure AD) — is Microsoft's cloud-based identity and access management service. It is the backbone of authentication for Microsoft 365, Azure, and thousands of third-party SaaS applications. Entra ID manages identities, authenticates users and applications, issues tokens, and enforces access policies. It is fundamentally different from on-premises Active Directory, which it replaces and extends for the cloud era.

The Six Identity Types

Entra ID handles multiple categories of identity, each with different management models and use cases:

Identity Type	Managed By	Description	Example
Cloud Identity (Internal User)	Entra ID	An identity that exists purely in the cloud with no on-premises counterpart. Standard identity for cloud-native organizations — M365, Azure, and SaaS apps.	Startup employee who only uses Microsoft 365
Service Principal / Managed Identity	Entra ID	A machine identity for applications and services — not a human. Service principals are manually registered. Managed identities are automatically managed by Azure, removing the need to handle credentials in code.	Azure Function that reads from a Key Vault

On-Premises Identity	Active Directory (AD DS)	An identity that originates in an on-premises Active Directory domain. Managed in AD, may be synchronized to Entra ID for hybrid access.	Corporate desktop joined to an on-prem domain
External B2B User	Partner's own IDP (via Federation)	A user from a partner organization who accesses your resources using their own credentials from their own identity provider. The identity itself is managed externally.	Consultant from an auditing firm needing SharePoint access
Guest User (B2B Collaboration)	Entra ID (your tenant)	An external user who is invited and explicitly managed inside your Entra ID tenant. May use a Microsoft account, Google account, or one-time passcode.	Contractor invited via email to collaborate in Teams
Hybrid Identity	AD DS + Entra ID (Entra Connect)	A user who has a single identity synchronized between on-premises Active Directory and Entra ID. Uses the same credentials for both on-prem resources and cloud services.	Bank employee who logs into on-prem AD and also uses Teams

B2B vs Guest: *External B2B: the user's identity lives in THEIR organization's directory — you never manage their credentials. Guest User: you create and manage a reference identity inside your own Entra ID tenant, giving you more direct control over their access.*

Authentication (AuthN) vs Authorization (AuthZ)

Authentication proves identity — it answers 'who are you?' Authorization determines access rights — it answers 'what are you allowed to do?' Authentication always happens first, and authorization uses its result.

	Authentication (AuthN)	Authorization (AuthZ)
Question answered	Who are you?	What are you allowed to do?
Happens	First — before any access is considered	After successful authentication
Result	A signed TOKEN containing identity claims	Permissions, roles, and access rights
Example action	User enters password + MFA code	User's 'Contributor' role allows VM creation
Microsoft tool	Entra ID — issues identity tokens	Azure RBAC, App registrations, permissions
If it fails	User cannot proceed at all	User can authenticate but access is denied

Modern Authentication Flow

Modern authentication replaces the old 'username and password sent directly to the server' model with a token-based system using an Identity Provider:

- Step 1: User enters credentials (username + password) in the client application.
- Step 2: The client sends credentials to the Identity Provider (Entra ID).
- Step 3: Entra ID validates credentials. If MFA is required, it prompts for the second factor.
- Step 4: Upon successful authentication, Entra ID issues a digitally signed TOKEN.
- Step 5: The token contains CLAIMS — username, roles, group memberships, expiry time.

- Step 6: The client presents this token to the target application or API.
- Step 7: The application validates the token's digital signature and reads the claims to determine access.

Single Sign-On (SSO): Once you have a valid token from Entra ID, you can present that same token to multiple applications without re-authenticating. The user logs in once; the token handles access to Teams, SharePoint, Dynamics, Salesforce, and more.

Multi-Factor Authentication (MFA)

MFA requires users to verify their identity using two or more independent factors from different categories. Even if an attacker steals a password, they cannot authenticate without also possessing the second factor. MFA blocks over 99% of credential-based attacks.

Factor Category	Explanation	Examples
Something You Know	A piece of knowledge only the user should have. Weakest factor when used alone — passwords can be phished, guessed, or stolen.	Password, PIN, security question answer
Something You Have	A physical or digital item in the user's possession. Much stronger — attacker needs to physically possess the device or intercept the code.	Authenticator app, OATH hardware token, SMS one-time code, smart card
Something You Are	A biological characteristic unique to the user. The strongest and most convenient factor — cannot be lost or stolen.	Fingerprint, facial recognition, iris scan, voice recognition

MFA Methods in Microsoft Entra ID

- Microsoft Authenticator App: The recommended option. Sends a push notification to the user's phone. User approves or denies. Supports number matching to prevent MFA fatigue attacks.
- OATH Hardware Token: A physical device that generates time-based one-time passwords (TOTP). 6-digit code changes every 30 seconds. Best for environments where phones are not permitted.
- SMS Text Message: A one-time code sent via SMS. Convenient but weakest MFA method — vulnerable to SIM-swapping attacks.
- Voice Call: An automated call to the user's phone. User presses a key to approve. Similar security profile to SMS.
- Windows Hello for Business: Biometric authentication (face, fingerprint, iris) or PIN tied to a specific device. Passwordless. Covered in detail below.
- FIDO2 Security Keys: Physical hardware keys. Fully phishing-resistant. The strongest available MFA option.

Passwordless Authentication

Passwordless authentication eliminates the password entirely, replacing it with stronger, phishing-resistant alternatives. All three Microsoft passwordless options use asymmetric cryptography — a private key stored securely on the authenticating device, with a corresponding public key registered in Entra ID.

Method	How It Works	Best Use Case
Windows Hello for Business	Uses a PIN or biometric (face, fingerprint, iris) tied to a specific Windows device. The PIN or biometric unlocks a private key stored in the device's TPM chip. The private key NEVER leaves the device. Even if the PIN is known, it only works on that specific device.	Corporate laptops and desktops. Each device is a unique credential.

Microsoft Authenticator App	The user's smartphone becomes their credential. When signing in, the app displays a push notification. User confirms with a biometric or PIN on their phone. No password is typed or transmitted.	Mobile workers. Requires a registered smartphone.
FIDO2 Security Keys	A physical hardware device (like a YubiKey) that plugs into USB or communicates via NFC. The key contains a private key tied to the specific website, making it fully phishing-resistant.	Shared workstations, high-security roles, environments where phones are restricted.

Conditional Access

Conditional Access is the Entra ID policy engine that evaluates context and enforces access decisions. It sits between the user and the application, inspecting every authentication attempt. It follows IF-THEN logic: IF these conditions are met, THEN enforce this control. It balances security with employee productivity.

Conditional Access Signals (Inputs)

Signal Type	What Conditional Access Evaluates
User and Group Identity	Who is signing in? What groups do they belong to? Do they have a high-privilege role (Global Admin, Security Admin)?
Location	Is the sign-in from a trusted named location (office IP range), an unexpected country, or an anonymous proxy/Tor exit node?

Device State	Is the device Entra-joined? Is it compliant with Intune policies (patched, encrypted, PIN enforced)? Is it a managed corporate device?
Application	Is the target app highly sensitive (HR, financial data) or low-risk (internal wiki)? Some apps warrant stronger controls.
Sign-in Risk Level	Entra ID Protection's ML model assesses each sign-in for risk: leaked credentials, impossible travel, anonymous IP, unfamiliar sign-in properties.
User Risk Level	Long-term risk assessment of the user account. Has this account shown sustained suspicious activity over time?

Access Outcomes (Enforcement)

Outcome	When Applied
Allow Access	All conditions are met and no elevated risk is detected — user proceeds without friction.
Require MFA	Conditions partially met or moderate risk — the user must complete a second factor before proceeding.
Block Access	Conditions not met or unacceptable risk — access is denied entirely with an explanation.
Require Compliant Device	The device must be enrolled in Intune and meet all compliance policies before access is permitted.
Require Terms of Use	The user must review and accept an acceptable use policy before accessing the resource.
Limit Session Scope	Access is permitted but with restrictions — read-only, no download, short session timeout, browser-only.

Identity Governance & Privileged Identity Management (PIM)

Identity Governance manages the complete lifecycle of identities and their access rights — from the moment someone joins the organization to the day they leave. It ensures the right people have access to the right resources for the right reasons.

Lifecycle Stage	How It Works	Example
Identity Lifecycle	Integration with HR systems means access is automatically provisioned when someone joins and deprovisioned when they leave. Role changes in HR automatically translate to permission changes in Entra ID.	Workday HR system triggers Entra ID to create account and assign groups when a new employee starts
Access Lifecycle	How existing employees request additional access, and how that access is periodically reviewed. Includes Access Reviews, Entitlement Management, and dynamic group membership.	Employee requests project SharePoint access → manager approves → auto-provisioned → access review 90 days later
Privileged Access Lifecycle	Special handling of high-risk administrative roles. PIM ensures no one has permanent standing admin access. All elevation is explicit, time-bound, and audited.	IT admin activates 'Network Contributor' role for 4 hours in PIM → access expires automatically

Privileged Identity Management (PIM) — Key Features

- Just-in-Time Activation: Eligible users must explicitly activate a role before using it. They specify a reason and duration. The role becomes active only when needed.
- Time-Bound Access: Activated roles automatically expire after a configured period (e.g., 1 hour, 8 hours). No way for the role to persist indefinitely.

- Approval Workflows: Sensitive roles can require approval from a designated approver before activation. The approver reviews the stated reason and approves or rejects.
- MFA on Activation: PIM can require MFA to be completed at the moment of role activation — even if the user already completed MFA at sign-in.
- Access Reviews: Periodic automated reviews that ask role owners: does this person still need this access? Reviewers approve, deny, or remove assignments.
- Audit History: Every role activation — who, when, which role, stated reason, duration, actions performed — is permanently logged for compliance and forensic investigation.

Why PIM Matters: *Without PIM, a compromised Global Admin account gives attackers immediate, full, persistent administrative control. With PIM, even if that account is compromised, the attacker has NO elevated permissions — they would need to explicitly activate a role, which triggers alerts, requires approval, and may require MFA.*

Active Directory vs Microsoft Entra ID

Active Directory Domain Services (AD DS) and Microsoft Entra ID are both identity platforms from Microsoft, but they were built for fundamentally different eras. Understanding their differences is crucial for hybrid environment design.

Characteristic	Active Directory (AD DS)	Microsoft Entra ID
Release / Origin	Windows 2000 Server	2010 as Azure AD; rebranded to Entra ID in 2023
Environment	On-premises servers only	Cloud-native; supports hybrid environments
Primary Protocols	Kerberos, NTLM, LDAP	OAuth 2.0, OpenID Connect, SAML 2.0
Device Management	Domain join — requires line-of-sight to DC	Entra join, Hybrid join, or registration via internet

SSO Scope	Within the domain/forest boundary	Across Azure, M365, and thousands of SaaS apps
External Users	Requires complex forest trust configurations	Native B2B collaboration and federation
MFA Support	Requires additional components (ADFS, NPS extension)	Native MFA — built-in, no additional servers needed
Management	Customer manages all domain controllers	Microsoft manages the service; customer configures
Internet Authentication	Not designed for internet-facing auth	Designed for internet-scale authentication

Federation & External Identities

Federation is a trust agreement between two independent identity providers. Rather than creating duplicate accounts, users from one organization can authenticate using their own IdP and access resources in a partner organization. The receiving organization trusts the sending organization's identity assertions — it does not manage the credentials itself.

- Federation is a TRUST RELATIONSHIP — not a replication of accounts. Company A trusts that Company B has properly authenticated its own users.
- Trust is not automatically bidirectional. If Company A trusts Company B, Company B does not automatically trust Company A.
- Entra ID can federate with partner organizations using SAML or WS-Federation protocols.
- Azure AD B2C can use social media providers (Google, Facebook, Twitter, LinkedIn, GitHub) as identity providers for consumer-facing applications.
- Entra ID Password Protection: Enforces a Global Banned Password List (Microsoft-maintained) and a Custom Banned Password List (admin-defined). This protection can also extend to on-premises Windows Server AD via an installed agent.

3. Microsoft Security Solutions

Microsoft provides a comprehensive, integrated security stack for Azure and Microsoft 365. The security portfolio spans network protection, identity security, cloud posture management, SIEM and SOAR, and extended detection and response across endpoints, identities, email, and cloud applications. Understanding which product addresses which threat — and how they interconnect — is essential.

Azure Network Security Services

Service	OSI Layer	Deployment	How It Works	Use Case
Network Security Group (NSG)	L3–L4 (IP/Port)	Subnet or NIC	Rules-based traffic filtering. Separate inbound and outbound rule sets. DENY ALL by default — all rules are explicit allowances. Stateful for TCP connections.	Block internet traffic to database subnet; allow only from app tier on port 1433
Azure DDoS Protection	Network / Transport	Virtual Network (Basic: free; Standard: paid)	Basic tier: always-on automatic mitigation. Standard tier: adds advanced telemetry, attack dashboards, mitigation reports, and	Absorb volumetric attack targeting a public IP of a web application

			DDoS cost protection.	
Azure Firewall	L3–L7 + IDPS + TLS	Hub VNet (centralized)	Fully managed stateful firewall. FQDN filtering, threat intelligence, IDPS (Intrusion Detection & Prevention), TLS inspection to detect threats in encrypted traffic.	Central egress control for all VNet-to-internet traffic; automatically block known malicious IPs
Web Application Firewall (WAF)	L7 (HTTP/HTTPS)	Azure Application Gateway or Front Door	Protects web applications from OWASP Top 10 attacks. Core Rule Sets, custom rules, and geomatch rules. Detection or prevention mode.	Protect a public API from SQL injection, cross-site scripting, and bot scanning
Azure Bastion	Management (RDP/SSH)	Per VNet	Provides secure browser-based RDP and SSH access to VMs without requiring public IPs on those VMs. Eliminates port 3389/22 internet exposure.	Admin connects to VM via browser — no VPN or public IP required on the VM

WAF — OWASP Attacks Blocked

Attack Type	What It Does
SQL Injection	Attacker inserts SQL commands into input fields to manipulate the database — reading, modifying, or deleting data.
Cross-Site Scripting (XSS)	Malicious JavaScript injected into a trusted website that executes in victims' browsers, stealing session cookies or credentials.
Command Injection	Attacker injects OS commands through application inputs, executing arbitrary code on the server.
HTTP Protocol Violations	Malformed requests that exploit weaknesses in how HTTP is parsed by proxies or application servers.
HTTP Request Smuggling	Exploits discrepancies between how frontend proxies and backend servers parse HTTP requests.
Remote File Inclusion	Application includes a remotely hosted malicious file via a URL parameter, executing attacker-controlled code.
Bot and Scanner Detection	Identifies and blocks automated malicious bots, vulnerability scanners, and credential-stuffing tools.
Application Misconfiguration	Detects attacks targeting common misconfigurations in Apache, IIS, PHP, and other web server software.

Azure Key Vault & Data Encryption

Azure Key Vault is the central service for managing secrets, cryptographic keys, and certificates. Its fundamental purpose is to remove sensitive values from application code, configuration files, and source control — the places where they are routinely leaked. Key Vault requires authenticated and authorized access before returning any secret.

Capability	Detailed Description

Secrets Management	Store and retrieve application secrets — database connection strings, API keys, tokens, passwords. Applications retrieve secrets at runtime via API calls, never storing them locally.
Cryptographic Key Management	Create, import, rotate, and retire encryption keys. Supports RSA and elliptic curve key types. Keys can be configured to expire automatically.
Certificate Management	Manage TLS/SSL certificates — create, store, auto-renew, and retrieve. Monitors and alerts on upcoming expiration.
HSM-Backed Operations	Premium tier stores keys in FIPS 140-2 Level 2 validated Hardware Security Modules. HSM-protected keys NEVER leave the HSM in plaintext — all cryptographic operations happen inside the module.
Access Control	Every secret retrieval requires the caller to authenticate via Entra ID AND be authorized via Key Vault access policies or Azure RBAC. Full audit log of every access operation.

Azure Data Encryption Options

Scope	Method	Description
Data At Rest	Service-Managed Keys	Default for ALL Azure services. Every Azure database, storage account, and AI service is automatically encrypted. No configuration required.
Data At Rest	Customer-Managed Keys (CMK)	Customer provides and manages encryption keys via Azure Key Vault. Customer controls key creation, rotation, and deletion. Deleting the key renders data permanently inaccessible.
Data At Rest	Client-Side Encryption	Application encrypts data before sending it to Azure. Azure only ever sees ciphertext — even Microsoft cannot read the data.

Data At Rest	Double Encryption	Data is encrypted twice — at the infrastructure layer and platform layer — using different keys. Available for Azure Managed Disks and other services.
Data In Transit	TLS / HTTPS	All data moving between clients and Azure services uses TLS. Azure Storage and SQL enforce HTTPS-only connections by default.
Data In Transit	MACsec (IEEE 802.1AE)	Encrypts data moving between Microsoft's own data centers over the WAN backbone. Protects against physical layer interception.

Microsoft Defender for Cloud & CSPM

Microsoft Defender for Cloud is a multi-cloud security platform combining Cloud Security Posture Management (CSPM) and Cloud Workload Protection Platform (CWPP) capabilities. It continuously monitors your cloud environment — Azure, AWS, and GCP — for security misconfigurations, vulnerabilities, and active threats. The highest percentage of cloud security incidents comes from misconfigurations and human error, not sophisticated hacking.

Function	What It Does	Example
Cloud Security Posture Management (CSPM)	Continuously analyzes the security state of your entire cloud environment. Identifies misconfigurations, excessive permissions, missing protections. Produces a Secure Score — a quantified measure of your security posture from 0–100%.	Defender notices storage accounts with public access enabled, NSGs with overly permissive rules, and VMs missing endpoint protection
Cloud Workload Protection (CWPP)	Real-time threat detection for specific workload types: virtual machines, SQL databases, containers, App	Defender detects crypto-mining malware on a VM, unusual outbound connections from a

	Service, Key Vault, DNS, and more. Each workload type has specialized threat detection algorithms.	container, or SQL injection against a database
DevOps Security Management	Integrates into CI/CD pipelines (GitHub, Azure DevOps, GitLab) to identify infrastructure-as-code misconfigurations and vulnerabilities in container images before they reach production.	Pull request scans find a Terraform file that would open port 22 to the internet before it is deployed

Secure Score, Recommendations & Attack Paths

- Secure Score: A percentage score representing how many security recommendations you have implemented. Each recommendation has a point value proportional to its security impact. Implementing it increases your score.
- Recommendations: Prioritized, actionable guidance for every identified issue. Each recommendation links to the affected resource, explains the risk, and provides step-by-step remediation guidance.
- Regulatory Compliance: Maps your current configuration against regulatory standards (PCI-DSS, ISO 27001, NIST, SOC 2). Shows exactly which controls are passing and failing.
- Cloud Security Explorer: A graph-based query interface. Allows security teams to query: 'Find all internet-exposed VMs with critical vulnerabilities that also have access to sensitive databases.'
- Attack Path Analysis: Identifies multi-step attack paths — for example, an internet-exposed VM with a vulnerability that also has access to a storage account containing sensitive data.

Microsoft Sentinel — SIEM & SOAR

Microsoft Sentinel is a cloud-native Security Information and Event Management (SIEM) and Security Orchestration Automated Response (SOAR) solution. It ingests security telemetry from across the entire enterprise — cloud and on-premises — and uses advanced analytics and AI to detect, investigate, and respond to threats.

Capability	Detailed Explanation	Example
SIEM (Security Information & Event Management)	Ingests data from connected sources — Azure services, M365, Entra ID, on-premises servers, network devices, and third-party products. Correlates events across data sources to detect threats no single log would reveal. Uses AI to minimize false positives while surfacing high-fidelity alerts.	Sentinel correlates: failed logins from Russia, then successful login, then large file download — generating an alert for potential account compromise and data exfiltration
SOAR (Security Orchestration Automated Response)	Takes alerts from SIEM and other sources and triggers automated playbooks (built with Azure Logic Apps). Playbooks can automatically block an IP, disable a compromised account in Entra ID, create a ServiceNow ticket, or send a Teams notification — without human intervention. Reduces Mean Time to Respond (MTTR) from hours to seconds.	Alert fires for suspicious IP → playbook automatically blocks IP in NSG, disables user account, creates P1 ticket, and pages on-call analyst — all in under 30 seconds

Sentinel Key Technical Capabilities

- Data Connectors: Pre-built connectors for Microsoft products (Entra ID, Defender, M365, Azure Activity) and hundreds of third-party products via syslog, CEF, and REST API.

- Analytics Rules: Scheduled or real-time KQL queries that detect specific patterns. Machine learning fusion rules correlate signals across multiple data sources automatically.
- Threat Hunting: Security analysts proactively hunt for indicators of compromise using KQL queries against all ingested data — not just waiting for alerts to fire.
- Workbooks: Interactive dashboards that visualize security posture, incident trends, threat actor activity, and geographic attack patterns.
- UEBA (User & Entity Behavior Analytics): Baseline normal behavior for each user and entity. Detect deviations that signal compromise — even when no specific attack signature matches.

Microsoft Defender XDR Suite

Extended Detection and Response (XDR) represents the evolution beyond point security products. XDR correlates signals from multiple security domains — endpoints, identities, email, cloud apps — into unified incidents. A phishing email that leads to credential theft, lateral movement, and data exfiltration appears as a single coordinated incident rather than disconnected alerts across multiple consoles.

Defender for Identity

Formerly Advanced Threat Protection (ATP). Monitors on-premises Active Directory and Entra ID to detect compromised identities, lateral movement, and privilege escalation attacks. Builds a behavioral baseline for every user.

Capability	What It Does
Behavioral Baseline	Learns what 'normal' looks like for each user — working hours, sign-in locations, accessed resources, and peer comparison
Kill-Chain Mapping	Maps detected activity to MITRE ATT&CK stages: initial access, privilege escalation, lateral movement, exfiltration
Attack-Specific Detection	Detects pass-the-hash, pass-the-ticket, golden ticket, silver ticket, Kerberoasting, and other AD-specific attacks

Lateral Movement Paths	Visualizes potential attack paths — showing how compromise of one account could lead to domain administrator
Noise Reduction	Provides high-fidelity alerts on a real-time attack timeline — reducing alert fatigue compared to raw log analysis

Identity Risk Signals

Risk Signal	What It Indicates
Anonymous IP Address	Sign-in originates from Tor browser, commercial VPN, or other anonymizing proxy service
Atypical Travel	User signs in from New York, then signs in from Tokyo 45 minutes later — physically impossible travel
Malware-Linked IP	Source IP associated with known botnets or malware command-and-control infrastructure
Leaked Credentials	Username/password found in a public breach database — Microsoft cross-references billions of leaked credentials
Password Spray Attack	Low-volume, slow attack trying a small number of common passwords across thousands of accounts to avoid lockout
Suspicious Inbox Rules	Automatic email forwarding to external address added after sign-in — common indicator of business email compromise

Defender for Office 365

Formerly Office 365 ATP. Protects email, collaboration tools, and document sharing from advanced threats. Available in two plans:

Plan	Feature	Description
Plan 1	Safe Attachments	Scans every email attachment in a sandboxed environment before delivery. Detonates potential malware harmlessly.
Plan 1	Safe Links	Rewrites all URLs in emails and Office documents. Checks the destination at click-time against threat intelligence. Blocks malicious URLs even if they were safe when the email arrived.
Plan 1	Anti-phishing Protection	ML-based detection of impersonation attacks, spoof intelligence, and lookalike domain detection.
Plan 1	SharePoint/OneDrive/Teams	Scans files uploaded to collaboration tools for malware using Safe Attachments detection engine.
Plan 2	Threat Explorer	Real-time view of email threats, investigations, and threat hunting capabilities for security analysts.
Plan 2	Attack Simulator	Run simulated phishing and password spray campaigns against your own employees to measure security awareness.
Plan 2	Automated Investigation & Response (AIR)	Automatically investigates alerts, determines scope, and takes remediation actions without analyst intervention.

Defender for Endpoint

Formerly Microsoft Defender ATP. Comprehensive endpoint security for Windows, macOS, Linux, iOS, and Android. Goes far beyond antivirus to provide full-spectrum endpoint detection and response.

Capability	What It Does
Threat & Vulnerability Management	Continuously discovers vulnerabilities and misconfigurations on enrolled endpoints. Prioritizes by risk score — not just CVSS severity — considering exploitability and business context.
Attack Surface Reduction (ASR)	Behavioral rules that block specific high-risk actions — running scripts from downloaded email attachments, launching child processes from Office applications, credential theft from LSASS.
Next-Generation Antivirus	Cloud-backed, AI-driven malware detection. Uses behavioral analysis and ML to detect novel threats that signature-based AV misses.
Endpoint Detection & Response (EDR)	Records rich telemetry — process execution trees, network connections, registry changes, file operations. Enables deep post-breach investigation.
Automated Investigation & Remediation	Automatically investigates alerts, traces the attack tree, and takes remediation actions (quarantining files, isolating devices) without analyst intervention.
Microsoft Secure Score for Devices	Measures the aggregate security posture of enrolled endpoints — patching status, security configuration, ASR rules enabled.

Defender for Cloud Apps (CASB)

Formerly Microsoft Cloud App Security. A Cloud Access Security Broker (CASB) that provides visibility and control over cloud application usage — both sanctioned Microsoft apps and unsanctioned third-party apps.

Capability	What It Does
Cloud Discovery / Shadow IT	Analyzes network traffic logs to identify all cloud apps in use — including unapproved shadow IT apps. Rates each app for risk based on 80+ factors.
App Governance & Control	Block or restrict access to risky apps. Set conditional access policies for specific cloud apps based on user, device, and activity context.
Information Protection	Extends Microsoft Purview DLP policies to cloud apps — detect and protect sensitive data in Salesforce, Box, Dropbox, and others.
Threat Detection	Detects ransomware activity, suspicious logins, mass downloads, impossible travel, and anomalies in cloud app usage patterns.
Session Control	Real-time proxy mode: allow access but block file downloads from unmanaged devices.

4. Microsoft Compliance Solutions

Compliance solutions help organizations govern, protect, and manage data while meeting regulatory requirements. Microsoft's compliance platform centers on Microsoft Purview — a unified service for data governance, information protection, and compliance management. Alongside Purview, Azure provides governance tools for controlling cloud resource configurations.

Microsoft Purview Platform

Microsoft Purview is a comprehensive data governance and compliance platform that helps organizations manage their data across on-premises environments, multiple cloud providers, and SaaS applications. Its goal is to provide a single, unified view of an organization's entire data estate — where data lives, how sensitive it is, who is accessing it, and whether it is being handled in compliance with policies and regulations.

Feature	What It Does
Compliance Manager	Prebuilt assessment templates for 300+ regulations. Generates a Compliance Score showing how well current configurations meet regulatory requirements. Provides step-by-step improvement actions with assigned ownership.
Compliance Score	A quantified measure of compliance posture. Scores improvement actions based on their risk reduction impact. Tracks progress over time and highlights gaps against specific regulatory frameworks.
Data Map	Automated scanning and cataloging of data sources — on-premises, Azure, AWS, GCP, and SaaS. Classifies discovered data by sensitivity. Tracks data lineage (where data comes from and where it goes).
Data Catalog	Searchable inventory of all organizational data assets. Business users can discover and understand data without needing to know its physical location.

Sensitive Information Types (SITs)	Pattern-matching rules that recognize specific data types: credit card numbers, SSNs, passport numbers, health record numbers. Used by DLP and auto-classification.
Trainable Classifiers	ML models trained to recognize document types by content — financial statements, employment contracts, source code, HR records — rather than keyword patterns.
Content Explorer	A read-only snapshot view showing every classified item across the organization. Answers: where does our sensitive data live?
Activity Explorer	Audit trail of actions taken on classified content — label applied/changed, file downloaded, copied to USB, uploaded externally. Answers: what is happening to our sensitive data?

Sensitivity Labels & Data Classification

Sensitivity labels are the cornerstone of Microsoft Purview's information protection strategy. They classify data based on its sensitivity level and can automatically enforce protection actions. Labels travel with the content wherever it goes — they are not tied to the location where the file was created.

Three Core Properties of Sensitivity Labels

- Customizable: Organizations define their own label taxonomy to match their data classification policy. A typical hierarchy: Public → Internal → Confidential → Highly Confidential → Restricted. Sub-labels add granularity (e.g., 'Confidential - Finance' vs 'Confidential - Legal').
- Clear Text: The label is stored as clear text in document metadata. This makes labels readable by third-party applications, DRM systems, and compliance tools without requiring Microsoft tools to interpret them.
- Persistent: The label stays with the content regardless of what happens to it — emailed externally, saved to a USB drive, or uploaded to a non-Microsoft cloud service.

What Sensitivity Labels Can Enforce

Action	What It Does
Encryption	Automatically encrypt the file or email. Define exactly who can open it, what permissions they have (view only, edit, print, forward), and whether access expires after a time period.
Visual Markings	Add headers, footers, and watermarks to documents and emails. Example: a bright red 'CONFIDENTIAL' header on every page.
Automatic Application	Automatically apply labels based on content matching — if a document contains 3+ credit card numbers, auto-apply 'Confidential - Payment Data' and encrypt it.
Container Protection	Apply sensitivity labels to SharePoint sites, Teams, and Microsoft 365 Groups. Control whether external sharing is allowed and what devices can access the site.
Rights Management (DRM)	Integrate with Azure Rights Management to define precise usage rights — who can read, edit, copy, print, or forward content — enforced even after the file leaves your organization.

Label Policies

Sensitivity labels must be published to users via label policies before they become available in Office applications. Label policies configure:

- Which users and groups can see and apply specific labels
- A default label for new emails and documents
- Whether users must apply a label before saving or sending (mandatory labeling)
- Whether users must provide a justification when downgrading a label classification
- Links to the organization's internal data classification guidance and help documentation

Data Loss Prevention (DLP)

Data Loss Prevention identifies sensitive information and prevents it from being accidentally or deliberately disclosed to unauthorized parties. DLP does not just block — it also educates. When a user is about to violate a DLP policy, a policy tip appears in real time, explaining the issue and offering guidance.

Scope	Coverage & Enforcement
Microsoft 365 DLP	Exchange Online (email), SharePoint Online (sites), OneDrive for Business (files), Microsoft Teams (messages and shared files). Scans content for sensitive information types and sensitivity labels.
Endpoint DLP	Windows 10 and Windows 11 devices enrolled in Microsoft Endpoint Manager. Monitors and restricts specific user actions on sensitive content at the device level.
Defender for Cloud Apps DLP	Extends DLP policies to sanctioned third-party cloud applications — Salesforce, ServiceNow, Box, Dropbox, Slack. Consistent data protection across your entire cloud app ecosystem.
Power Platform DLP	Governs data connector usage in Power Automate and Power Apps — controlling which services can be connected to and whether sensitive business data can flow to external connectors.

Endpoint DLP — Activities Monitored on Windows Devices

- Creating or renaming files containing sensitive information
- Copying sensitive files to removable media (USB drives, external hard drives)
- Copying sensitive files to network shares (including cloud sync folders)
- Printing documents containing sensitive information
- Uploading sensitive files to non-corporate cloud services (personal Google Drive, Dropbox)
- Accessing sensitive content with unallowed browsers or applications

Retention Policies, Retention Labels & Records Management

Retention management ensures content is kept for exactly as long as required — no longer, no less. Regulations often require specific retention periods. Keeping data beyond its required period increases legal liability. Deleting it too early may violate regulatory requirements or obstruct legal proceedings.

Retention Labels vs Retention Policies

Characteristic	Retention Labels	Retention Policies
Applied At	Item level — individual file, document, email	Container level — SharePoint site, Exchange mailbox, OneDrive account
Content Movement	Label TRAVELS with the item when moved within M365 tenant	Settings do NOT travel with content when moved
Disposition Review	Supported — review before permanent deletion	Not supported
Records Management	Can mark items as Records or Regulatory Records	Not applicable — policies manage retention, not record status
Best Use Case	Specific high-value documents needing individual lifecycle management	Broad governance across large volumes of content

Records Management — Types of Records

- Retention Label (Standard): Basic classification. Items are retained per policy but can still be edited and deleted by authorized users.
- Record (Unlocked): Item is marked as a record. Can still be edited. Once editing is complete, can be locked.
- Record (Locked): Read-only. Cannot be modified. Users can view and comment but not change the content.

- Regulatory Record: Strictest classification. Cannot be unlocked, modified, or deleted by anyone — including Global Administrators — until the retention period expires. Requires special admin permissions to create.

eDiscovery

Tier	Capabilities
eDiscovery Standard	Content search across Exchange, SharePoint, OneDrive, Teams. Legal hold — preserves content even if users delete it. Export results for legal review. Core case management.
eDiscovery Premium	Everything in Standard plus: advanced indexing, custodian management workflow, review sets with analytics, relevance scoring, near-duplicate detection, email threading, and privilege detection.

Insider Risk Management & Communication Compliance

Internal threats — whether from malicious insiders, negligent employees, or compromised accounts — are among the hardest to detect with traditional perimeter security. Microsoft Purview provides four solutions targeting internal risk:

Solution	How It Works	Example
Communication Compliance	Scans communications across Teams, Exchange, Yammer, and third-party platforms for policy violations. Detects profanity, threats, harassment, sharing of sensitive information, and regulatory violations.	Detect an employee harassing a colleague in Teams; detect a trader discussing non-public information via email
Insider Risk Management	Detects behavioral patterns indicating insider threats: IP	Employee gives two-week notice; system flags unusual

	theft, data leakage, policy violations. Correlates HR signals (resignation notice) with data activity spikes (mass downloads, USB exports).	upload of 2,000 files to personal Dropbox that week
Information Barriers	Restricts communications and collaboration between defined user groups. Only supports two-way restrictions. In Teams: blocks search, messaging, adding to teams, and shared file access.	Day traders cannot message, search for, or share files with investment banking employees
Privileged Access Management (PAM)	Controls and requires approval for highly privileged Exchange Online administrative tasks. Every privileged action requires an explicit just-in-time approval with a full audit trail.	IT admin needs to modify a sensitive mailbox export setting — submits PAM request, approver approves for 1 hour

Information Barriers: *Information Barriers only support TWO-WAY (bidirectional) restrictions. If Group A cannot communicate with Group B, then Group B also cannot communicate with Group A. There is no one-directional option.*

Azure Policy, Blueprints, Resource Locks & Service Trust Portal

Azure Policy

Azure Policy helps enforce organizational standards and assess compliance across all Azure resources and Arc-enabled resources. Policies evaluate resources against defined rules and respond based on the configured effect:

Effect	What It Does

Deny	Prevents a non-compliant resource from being created or modified. The most proactive effect — stops violations before they occur.
Audit / AuditIfNotExists	Allows the change but logs the compliance violation. Used for non-critical policies where visibility is needed without blocking.
Modify / DeployIfNotExists	Automatically alters a resource to bring it into compliance, or deploys a related compliant resource. Example: automatically add diagnostic logging to any new storage account.
Append	Adds additional properties to a resource being created, such as required tags for cost allocation.

Azure Blueprints

Azure Blueprints define a repeatable set of Azure resources that must be deployed together to meet an organization's compliance requirements. A blueprint can include Role Assignments, Policy Assignments, ARM templates, and Resource Group definitions — all version-controlled and deployable to multiple subscriptions simultaneously. They enable organizations to enforce a compliant environment from day one.

Azure Resource Locks

Resource locks prevent accidental deletion or modification of Azure resources. Locks are inherited — a lock applied to a subscription applies to all resource groups and resources within it.

Lock Type	What It Allows / Prevents
CanNotDelete	Users can read and modify the resource but cannot delete it. Protects against accidental or unauthorized deletion of critical infrastructure.

ReadOnly	Users can read the resource but cannot modify or delete it. Equivalent to giving everyone Reader role permissions, regardless of their actual RBAC assignments.

Microsoft Service Trust Portal & Privacy Principles

The Microsoft Service Trust Portal (https://servicetrust.microsoft.com) is the centralized repository for documentation about Microsoft's security, compliance, and privacy practices. It provides audit reports (SOC 2, ISO 27001, FedRAMP), compliance guides, and whitepapers.

Microsoft's Six Privacy Principles:

- Control: Users are in control of their privacy with easy-to-use tools and clear choices about data collection and use.
- Transparency: Microsoft is transparent about what data it collects, why it is collected, and how it is used.
- Security: Microsoft uses strong security and encryption to protect the data it collects and processes.
- Strong Legal Protections: Microsoft respects local privacy laws globally and actively fights for user privacy rights in legal proceedings.
- No Content-Based Targeting: Microsoft does not use the content of documents, emails, or files to target advertising to users.

Benefits to You: Data that Microsoft collects is used only to improve the user's experience and Microsoft services — not sold to advertisers.